

الوحدة 28: إدارة الطرف الثالث والتوعية الأمنية

(Third-Party Risk (SolarWinds

مخاطر الطرف الثالث: الثغرات التي تأتي من الموردين والشركاء والموزعين. حادثة (SolarWinds 2020) مثال شهير حيث اخترق المهاجمون عملية بناء تحديث برنامج Orion وأدخلوا بابًا خلفيًا (Sunburst) أثر على 18,000 عميل بما فيها وكالات حكومية أمريكية.

استراتيجيات إدارة مخاطر الطرف الثالث:

- **Vendor Due Diligence:** فحص المورد قبل التعاقد (تاريخه، شهاداته، ممارساته الأمنية).
- **Security Questionnaires:** استبيانات أمنية (مثل SIG, CAIQ).
- **Penetration Testing:** اختبار اختراق لخدمات المورد.
- **Third-Party Risk Assessments:** تقييم دوري (سنوي أو ربع سنوي).
- **SLAs (Service Level Agreements):** اتفاقيات مستوى الخدمة تشمل البنود الأمنية (وقت الاستجابة، التشفير).
- **Dependencies Analysis:** تحليل التبعية (هل ناعتمد على مورد واحد؟).
- **Right to Audit:** الحق في تدقيق المورد.

Bug Bounty / Responsible Disclosure

Bug Bounty: برنامج يدفع مكافآت مالية للباحثين الأمنيين (White Hat) لاكتشاف الثغرات. مثال: HackerOne, Bugcrowd.

Responsible Disclosure: الإفصاح المسؤول - يبلغ الباحث الشركة بالثغرة ويعطيها مهلة (عادة 30-90 يومًا) لإصدار تصحيح قبل النشر العام.

Full Disclosure: نشر تفاصيل الثغرة فورًا للعامة (نادر ويُعتبر خطيرًا).

Red / Blue / Purple Team

- Red Team:** فريق الهجوم - يحاكي المهاجمين الحقيقيين لاختبار الدفاعات.
- Blue Team:** فريق الدفاع - يراقب ويكشف ويستجيب للهجمات (SOC, Incident Response).
- Purple Team:** تنسيق بين الأحمر والأزرق لتحسين الدفاعات.

Security Awareness Training

التوعية الأمنية للموظفين هي خط الدفاع الأول (وأضعف حلقة). يجب أن يكون التدريب مستمرًا وتفاعليًا وليس مرة واحدة في السنة فقط.

المحاور الرئيسية:

- **Phishing Simulation:** إرسال رسائل تصيد تجريبية وقياس استجابة الموظفين.
- **Password Hygiene:** استخدام كلمات مرور قوية (+12 حرف)، مدير كلمات مرور، المصادقة متعددة العوامل (MFA).
- **Social Engineering:** التوعية بهندسة الاجتماعية (المكالمات، التسلل، الذريعة).
- **Physical Security:** عدم ترك الشاشات مفتوحة، قفل الأبواب، منع Tailgating.

- **Clean Desk Policy**: عدم ترك أوراق حساسة أو أجهزة USB على المكتب.
 - **Safe Internet Usage**: عدم تحميل برامج غير مصرح بها، تجنب المواقع المشبوهة.
 - **Incident Reporting**: الإبلاغ الفوري عن الحوادث الأمنية (من يصادف حادثاً).
- مقاييس فعالية التدريب: نسبة الإبلاغ عن التصيد، نتائج الاختبارات، عدد الحوادث الناتجة عن خطأ بشري.

مثال: قائمة التوعية الأمنية (Security Awareness Checklist)

- ✓ استخدام كلمة مرور قوية (12+ حرف، رموز)
- ✓ عدم فتح مرفقات مشبوهة
- ✓ التحقق من مرسل البريد الإلكتروني
- ✓ قفل الشاشة عند مغادرة المكتب (Win+L)
- ✓ الإبلاغ عن الحوادث الأمنية فوراً
- ✓ تحديث الأنظمة والبرامج
- ✓ مجهول المصدر USB عدم استخدام

مثال: nmap لاكتشاف خدمات الموردين

```
nmap -sV -p 443,80,22 --open vendor-domain.com
```

يشرح الأمر كالتالي:

- nmap : أداة مسح الشبكات.
- sV- : كشف إصدارات الخدمات.
- p 443,80,22- : المسح على المنافذ (HTTPS, HTTP, SSH).
- open-- : يعرض المنافذ المفتوحة فقط.
- vendor-domain.com : نطاق المورد المراد فحصه.

Supply Chain Security

أمن سلسلة التوريد: حماية كل حلقة في سلسلة توريد المنتج من الموردين إلى المستخدم النهائي. الهجمات على سلسلة التوريد في ازدياد:

- **Hardware Implants**: شرائح ضارة تُزرع في الأجهزة أثناء التصنيع.
 - **Software Backdoors**: أبواب خلفية تُضاف للبرامج قبل التوزيع.
 - **Compromised Firmware**: برامج ثابتة (Firmware) مخترقة على اللوحة الأم أو BIOS.
 - **Third-Party Libraries**: مكتبات برمجية ملوثة (مثل event-stream في npm أو log4j).
 - **Code Repositories**: اختراق مستودعات الكود المصدري (GitHub, GitLab).
- (SBOM) **Software Bill of Materials**: قائمة بكل المكونات البرمجية في التطبيق. يساعد في تتبع التبعية واكتشاف الثغرات بسرعة.

(Quick Quiz (MCQ

?What made the SolarWinds attack a supply chain attack .1

- a) It targeted physical supply warehouses
- b) Malicious code was inserted into a legitimate software update
- c) It used a denial-of-service method
- d) It compromised only open-source software

Answer: b

?What is the key difference between Responsible Disclosure and Full Disclosure .2

- a) Responsible Disclosure gives vendors time to fix before public release, Full Disclosure publishes immediately
- b) Responsible Disclosure is illegal, Full Disclosure is legal
- c) There is no difference
- d) Full Disclosure involves law enforcement

Answer: a

?What is a Red Team in cybersecurity .3

- a) The team that monitors SIEM alerts
- b) An offensive team that simulates real-world attacks
- c) The team that manages firewall rules
- d) The team that handles patch management

Answer: b

?Which is considered the strongest defense against social engineering attacks .4

- a) Antivirus software
- b) Security awareness training for all employees
- c) Network firewalls
- d) Intrusion detection systems

Answer: b

?What does SLA stand for in vendor management .5

- a) Security Level Agreement
- b) Service Level Agreement
- c) System Licensing Agreement
- d) Standard Log Audit

Answer: b